

Industrial Security (Bachelor)

Solution Sheet – Section 07

Risk Management

Marking note. Each solution box gives a sample answer plus *rubric hints*: what a good answer must contain, common mistakes, and the standards a student is expected to cite. The numerical values used in LOPA and FAIR sub-tasks are *indicative* – accept any defensible range that the student justifies.

Solution

Exercise 7.1 – 5×5 Risk Matrix. A defensible policy: green = (likelihood + consequence) ≤ 3 ; yellow = 4–5; orange = 6; red = ≥ 7 . Sample placement: (a) historian ransomware – Likely / Moderate (yellow): annoying but no process impact if backups work; (b) spoofed Modbus write to dosing setpoint – Possible / Major (orange): public-health consequence; (c) stolen laptop with cached HMI password – Possible / Major (orange): direct path to setpoints; (d) cellular link loss 30 min – Likely / Minor (yellow): local PLC keeps running; (e) vendor session left open weekend – Possible / Catastrophic (red): unsupervised privileged access to safety-relevant equipment. **Rubric:** student must (i) state the colour rule explicitly, (ii) justify each placement with reference to the OT consequence dimensions, (iii) recognise (e) as the highest because of unsupervised privileged access. Common mistake: putting (a) in red because “ransomware sounds bad” without considering containment.

Solution

Exercise 7.2 – Bow-Tie (chlorine setpoint). Sample causes (left): C1 insider with HMI rights changes setpoint; C2 Modbus write injection from compromised engineering laptop; C3 operator typo during shift handover (human error). Consequences (right): K1 under-chlorination → microbial breakthrough (safety / public health); K2 over-chlorination → taste complaints & EPA / drinking-water-regulator reporting (regulatory); K3 plant shutdown to flush and re-sample (production). Preventive barriers: P1 role-based access on HMI with named accounts (procedural / technical); P2 Modbus write allow-list at the IDS / firewall on the conduit between HMI and PLC (technical). Mitigating barriers: M1 independent online residual analyser with hardware alarm and auto-shutoff (technical / physical); M2 written customer-notification SOP ≤ 1 h after detection (procedural). **Rubric:** barriers must be *independent* of the cause they protect against; a barrier that runs on the same compromised HMI does not count. Good answers explicitly label each barrier (procedural / technical / physical).

Solution

Exercise 7.3 – Cyber-HAZOP on P-101. *No flow:* attacker writes pump-speed setpoint to 0 via Modbus → loss of cooling, exotherm in R-201. *More flow:* attacker raises setpoint above design → pump cavitation, mechanical damage, possible loss of suction. *Less flow:* attacker degrades setpoint slowly (ramp below alarm rate-of-change) → creeping temperature rise undetected by the $\pm 20\%$ deviation alarm. *Reverse flow:* attacker disables check-valve actuator and stops pump → reactor contents back-flow into supply, contamination. *As well as:* attacker injects a spoofed “flow OK” value in parallel with the real one → operator sees normal reading while real flow is zero (loss of view). **Rubric:** answers must distinguish the *cyber* cause from a random equipment failure (e.g. “setpoint written by attacker”, not “pump fails”). Cite IEC 61882 for the guide words and ISA TR84.00.09 for the cyber adaptation. “Loss of view” (the “as well as” case) is the subtle one and earns full marks.

Solution

Exercise 7.4 – LOPA Calculation. Credited IPLs with typical PFDs (per CCPS LOPA): BPCS flow loop – *not* an IPL because the initiating event is its failure (independence rule); high-T alarm + operator response PFD = 1×10^{-1} ; SIS SIL-2 trip PFD = 1×10^{-2} ; PSV PFD = 1×10^{-2} . Residual: $f_{\text{mit}} = 0.1 \cdot 10^{-1} \cdot 10^{-2} \cdot 10^{-2} = 1 \times 10^{-6}$ /year (one event per million years – well within most company appetites for a runaway exotherm). **Key assumption:** the three layers are *independent*. If the SIS shares the same engineering workstation as the BPCS, a single cyber compromise removes both layers and the math is wrong; IEC 61511 mandates this independence. **Rubric:** full marks require (i) excluding the BPCS loop as an IPL because it is the initiating event source, (ii) multiplying PFDs correctly, (iii) naming the independence assumption. Common mistake: crediting the BPCS twice.

Solution

Exercise 7.5 – CCE Phase 1. Sample top-three unacceptable outcomes for a speciality-chemicals site: **(1)** toxic release from a storage tank into the neighbouring community – ranked first because it is the only outcome that can produce off-site fatalities and the only one that almost certainly ends the licence to operate. **(2)** runaway exotherm in a batch reactor causing on-site fatality and a multi-week shutdown – ranked second: catastrophic to staff and the business but contained to the fence-line. **(3)** rail-loading mis-routing causing wrong-product delivery to a customer (e.g. a strong acid labelled as solvent) – ranked third: severe regulatory / liability exposure and brand damage but recoverable. **Next phase:** CCE Phase 2 – *System-of-systems analysis* – maps the cyber / digital and supply-chain dependencies for each of the prioritised consequences (what would have to fail to realise outcome 1?). **Rubric:** reject lists of > 5 consequences (Phase 1 is about ruthless prioritisation). Accept reasonable ranking criteria as long as they are explicit (off-site harm, irreversibility, licence to operate).

Solution

Exercise 7.6 – Risk Response. Transfer. Right: cyber-insurance to cover business-interruption loss after ransomware on a corporate ERP (large, low-probability, non-safety). Wrong: transferring a safety risk (“insurance will pay if someone dies”) – the residual harm to humans is not transferred; mitigate or avoid instead. **Accept.** Right: a legacy serial RS-232 link to a stand-alone analyser, air-gapped, with no remote write path – documented, signed-off, reviewed annually. Wrong: accepting an Internet-exposed HMI because “no incident yet” – this is acceptance by default, not by decision; avoid (remove the exposure). **Mitigate.** Right: deploy MFA, segmentation and EDR on the engineering-workstation tier to reduce both likelihood and consequence of ransomware. Wrong: mitigating around a fundamentally unsafe practice such as routine remote programming of an SIS during operation – the right answer is *avoid* (key-switch in RUN, no remote writes). **Avoid.** Right: decommission the unused dial-up modem on the PLC. Wrong: “avoiding” a critical vendor remote-support tunnel that the operator depends on for emergency fixes – you lose recovery capability; mitigate (brokered, recorded, MFA) instead. **Rubric:** students must give a concrete OT artefact for each, not generic IT examples. Marking the wrong-choice case is the discriminator.

Solution

Exercise 7.7 – Merck v. Ace American. The insurer denied USD 1.4 bn of Merck’s NotPetya loss by invoking the “hostile or warlike action” exclusion, arguing that NotPetya was a Russian state-attributed attack on Ukraine and therefore an act of war. The New Jersey Appellate Division held that the exclusion clause, as written in Merck’s all-risk property policy, had historically been understood to cover *kinetic* military action; it could not be stretched, without notice to the insured, to cover a state-attributed cyber operation in a peace-time commercial

network. Merck was therefore covered. **Consequences for an OT operator in 2026:** (i) modern policies have been re-written with explicit “cyber-war” or “state-attributed attack” exclusions (Lloyd’s market bulletin 2022) – read them carefully; (ii) expect attribution clauses that defer to government attribution statements (NCSC, CISA), sub-limits for critical-infrastructure operators, and required control baselines (MFA, EDR, immutable backups) as preconditions to cover. **Why insurance is not a substitute for safety mitigation:** insurance pays money after the fact; it does not bring back staff, reverse a toxic release, or restore a regulator’s trust. For any risk whose consequence dimension is *safety* or *environment*, ALARP / inherent-safety reasoning applies and the risk must be driven down regardless of insurability. **Rubric:** full marks require recognising both the policy-wording point and the safety-vs-financial-loss distinction.

Solution

Exercise 7.8 – FAIR Estimate (historian ransomware). Sample values (defensible, not authoritative): **TEF** = 2 / year – ransomware actors reach Internet-exposed corporate assets routinely; reaching the historian requires crossing into Level 3, so the rate is lower than for IT (use a most-likely value with a range, e.g. 1–5/year). **Vulnerability** = 0.10 – current controls (network segmentation, EDR, monthly offline backup, MFA on jump host) defeat most actions; roughly one in ten attempts succeed end-to-end. **Loss Magnitude:** primary – $\approx$ EUR 80,000 (IR retainer EUR 30k, internal labour EUR 20k, restore + revalidation EUR 30k); secondary – $\approx$ EUR 70,000 (regulator notification, late-reporting fines, customer credits) $\Rightarrow$ **LM** $\approx$ EUR 150,000. **Loss Exposure** = $2 \times 0.10 \times 150,000 =$ EUR 30,000 / year. **Biggest uncertainty:** the *Vulnerability* factor – it depends on the realism of the offline backup test; if backups have never been restored end-to-end, the true Vuln is closer to 0.5 and the loss exposure jumps to EUR 150,000 / year. **Rubric:** accept any internally consistent number set, but the student must (i) show the arithmetic, (ii) name a primary and a secondary loss category, (iii) identify the dominant uncertainty. Reject single point estimates with no range or assumption.

Solution

Exercise 7.9 – Risk Register Row. Sample row for the lab: **ID:** R-OT-014. **Description:** “Default credentials on lab OpenPLC web HMI permit unauthenticated setpoint writes from any host on the lab VLAN, risking unintended physical actuation of the demo conveyor.” **Likelihood:** *Likely* (4/5) – the credentials are documented in the vendor manual and known to all students. **Consequence:** *Moderate* (3/5) – demo equipment can pinch fingers; no chemical or process risk in this lab. **Owner:** Lab supervisor (Prof. X). **Treatment:** *Mitigate* – change default password, restrict HMI to lab-host /24, enable session timeout (10 min). **Residual rating:** *Unlikely / Minor* (yellow) after treatment. **Review date:** 30 September 2026 (start of winter semester). **Rubric:** reject rows with vague ownership (“IT”) or no review date. The residual rating must be *lower* than the inherent rating, and the student must say so explicitly.

Solution

Exercise 7.10 – False Precision. What is wrong: (i) two decimals on a 10-point qualitative scale imply $\sim 1\%$ measurement resolution that the inputs do not support; (ii) no confidence interval / range is given, so the score hides its own uncertainty; (iii) the weighting and aggregation of factors is opaque – a single “score” suggests the factors are independent and commensurable, which they almost never are. **Questions to the vendor:** (1) What is the underlying data (CVE feed? asset inventory? telemetry?) and how recent is it? (2) How are factor weights chosen and have they been calibrated against real incident data? (3) Are the factors statistically independent, or are you double-counting (e.g. “patch level” and “CVE count” on the same PLC)? (4) What is the confidence interval / sensitivity of the score? Show me the same calculation with ± 1 standard deviation on each input. **Defensible alternative:** report a NIST SP 800-30

semi-quantitative band (Very Low / Low / Moderate / High / Very High) with the rationale, or a FAIR loss-exposure range in money with explicit min / most-likely / max values (Jones & Freund). Either makes the uncertainty visible instead of laundering it through a false-precision number. **Rubric:** students must hit all three methodological issues in part (1) and at least three of the four vendor questions; bonus marks for naming sensitivity analysis or Monte Carlo as the way to surface the confidence interval.